

Fireblocks - Unauthenticated Health Endpoint Discloses Internal Infrastructure Metadata

Target: <https://sb-mobile-api.fireblocks.io/health> | Bugcrowd submission draft

Field	Value
Target	https://sb-mobile-api.fireblocks.io/health (in scope)
Program	Fireblocks Web Managed Bug Bounty Engagement (Bugcrowd)
Suggested severity	P4 - Sensitive Data Exposure / Security Misconfiguration
Observed	2026-09-15, single unauthenticated GET request
Reporter	sohrab

1. Summary

The Fireblocks sandbox mobile API exposes its **/health** endpoint without authentication. The JSON response includes internal infrastructure metadata such as an AWS account ID, SNS topic ARNs, SQS queue URLs, an S3 bucket name, RabbitMQ component names, and live JVM heap/RSS memory values. This discloses a meaningful portion of the backend's internal cloud and service topology to any unauthenticated requester.

2. Steps to reproduce / Proof of Concept

- 1 Send an unauthenticated **GET** request to <https://sb-mobile-api.fireblocks.io/health>.
- 2 No token, cookie, API key, or other authentication material is required.
- 3 Observe that the response returns detailed health information for internal AWS and application components, rather than only an aggregate status.

Request

```
GET /health HTTP/1.1
Host: sb-mobile-api.fireblocks.io
User-Agent: Mozilla/5.0 (compatible; BugBountyResearcher)
```

Response excerpt

```
{
  "details": {
    "s3": {"status": "up", "details": {"fireblocks-sandbox-messages": {"healthy": true}}},
    "database": {"status": "up"},
    "redis": {"status": "up"},
    "sns": {"status": "up", "details": {
      "arn:aws:sns:us-east-2:751886943440:sandboxAggregator": {"healthy": true},
      "... additional topic ARNs ...": {"healthy": true}
    }},
    "sqs": {"status": "up", "details": {
      "https://sqs.us-east-2.amazonaws.com/751886943440/sandboxCoreZin": {"healthy": true},
      "... additional queue URLs ...": {"healthy": true}
    }},
    "rabbitmq": {"status": "up", "details": {"RabbitmqWebSocketListener": {"healthy": true}}},
    "heapMemory": {"status": "up", "details": {"used": 143719040, "threshold": 1073741824}},
    "rssMemory": {"status": "up", "details": {"used": 317169664, "threshold": 3145728000}}
  },
  "info": { "... same detailed component information is also returned ..." }
}
```

3. Live evidence

The browser rendering below shows the endpoint returning the detailed JSON response without authentication.

Pretty-print ☐

```
{
  "details": {
    "s3": {
      "status": "up",
      "details": {
        "fireblocks-sandbox-messages": {
          "healthy": true
        },
        "database": {
          "status": "up",
          "redis": {
            "status": "up",
            "sns": {
              "status": "up",
              "details": {
                "arn:aws:sns:us-east-2:751886943440:sandboxAggregator": {
                  "healthy": true,
                  "arn:aws:sns:us-east-2:751886943440:sandboxAudit": {
                    "healthy": true,
                    "arn:aws:sns:us-east-2:751886943440:sandboxOfflineConsole": {
                      "healthy": true,
                      "arn:aws:sns:us-east-2:751886943440:sandboxMobileApiGateway": {
                        "healthy": true,
                        "sns": {
                          "status": "up",
                          "details": {
                            "https://sqs.us-east-2.amazonaws.com/751886943440/sandboxMPCMobile": {
                              "healthy": true,
                              "https://sqs.us-east-2.amazonaws.com/751886943440/sandboxMPCMobileApp": {
                                "healthy": true,
                                "https://sqs.us-east-2.amazonaws.com/751886943440/sandboxAggregator": {
                                  "healthy": true,
                                  "https://sqs.us-east-2.amazonaws.com/751886943440/sandboxAggregatorPreProc": {
                                    "healthy": true,
                                    "rabbitmq": {
                                      "status": "up",
                                      "details": {
                                        "RabbitmqWebSocketListener": {
                                          "healthy": true,
                                          "RabbitConnector": {
                                            "healthy": true
                                          },
                                          "heapMemory": {
                                            "status": "up",
                                            "details": {
                                              "used": 141800248,
                                              "threshold": 1073741824
                                            },
                                            "rssMemory": {
                                              "status": "up",
                                              "details": {
                                                "used": 294223872,
                                                "threshold": 3145728000
                                              }
                                            },
                                            "status": "ok"
                                          }
                                        }
                                      }
                                    }
                                  }
                                }
                              }
                            }
                          }
                        }
                      }
                    }
                  }
                }
              }
            }
          }
        }
      }
    }
  }
}
```

Figure 1 - Browser response from **sb-mobile-api.fireblocks.io/health**. The screenshot contains AWS resource identifiers, component health data, and runtime memory values.

4. Disclosed data

Category	Observed disclosure
AWS identity / region	AWS account ID 751886943440; region us-east-2
SNS	5 topic ARNs revealing internal topic naming and component relationships
SQS	5 queue URLs, including sandboxCoreZin, sandboxMPCMobile, sandboxMobileApp, sandboxAggregator, and sandboxAggregatorPreProc
S3	Bucket name: fireblocks-sandbox-messages
RabbitMQ	Component names including RabbitmqWebSocketListener and RabbitConnector
Runtime telemetry	Live JVM heap and RSS memory usage and configured thresholds

5. Security impact and severity rationale

An unauthenticated party can use the response to map internal naming conventions and cloud resources, identify the AWS account and region, learn queue/topic relationships, and collect live runtime telemetry. This information can reduce the cost of reconnaissance and make later targeting or social-engineering attempts more precise.

Important scope note: the evidence demonstrates information disclosure only. No credentials, secrets, or direct unauthorized access to the disclosed AWS resources were demonstrated. For that reason, **P4 / Sensitive Data Exposure** is a conservative and supportable severity assessment based on the current evidence.

6. Recommended remediation

- Restrict **/health** to an internal network/interface or require authentication equivalent to sibling application routes.
- For any externally reachable health endpoint, return only a minimal aggregate status such as **{"status":"ok"}**.
- Remove resource names, ARNs, queue URLs, bucket names, component names, and runtime telemetry from unauthenticated responses.
- Review other health/debug/status endpoints for the same configuration pattern.